Security Analysis and Mitigation of Credential–Endpoint Binding Vulnerabilities in the Universal Tool Calling Protocol (UTCP)

KRISHNA S
MSc AI & CS
Department of Computer Science
Christ University, Bangalore, India

VISHNU S S
MSc AI & CS
Department of Computer Science
Christ University, Bangalore, India

Dr. HEMANTH K S
Research Guide
Department of Computer Science
Christ University, Bangalore, India

***Abstract*— AI agents are increasingly using tool-calling protocols to interact with external services and perform different tasks. The Universal Tool Calling Protocol (UTCP) provides a way for applications to discover and execute tools through Manuals, Tool metadata, endpoints, and authentication credentials. However, when these components are not properly validated, a credential intended for one trusted endpoint may be used with another unauthorized endpoint.**

This research studies the security of credential–endpoint binding in UTCP. A controlled experimental environment was created using two local HTTP servers, where one server represented the trusted endpoint and the other represented an unauthorized endpoint. Four security scenarios were tested: modified Tool endpoints, malicious Tool metadata, attacker-controlled Manual registration, and untrusted user-supplied Manual registration. The experiments showed that the first two scenarios could result in credential transmission to an unauthorized endpoint, while the other two demonstrated unauthorized Manual registration paths.

Based on these findings, a unified mitigation mechanism was developed to check credential–endpoint authorization, Tool metadata endpoints, Manual identity and source, and user trust before allowing the corresponding operation. The mitigation successfully detected and blocked the unauthorized conditions identified during the experiments. The study provides a practical foundation for improving credential protection and trust validation in UTCP-based Tool execution.

Keywords*— *Universal Tool Calling Protocol, UTCP Security, Credential–Endpoint Binding, AI Agent Security, Tool Calling, Endpoint Security, Manual Registration, Credential Protection.

I. INTRODUCTION

Today, AI systems are increasingly being used to perform tasks by interacting with external tools and services. AI agents can use tool-calling protocols to discover available tools, provide the required inputs, and execute operations without requiring every action to be performed manually. The Universal Tool Calling Protocol (UTCP) provides a structured approach for discovering and executing tools through components such as Manuals, Tool metadata, communication protocols, endpoints, and authentication credentials. As the use of tool-calling systems increases, protecting these components becomes important because they can influence how and where a Tool is executed.

One important security concern in UTCP is the relationship between a credential and its authorized endpoint. A credential configured for a trusted service should only be transmitted to the endpoint that is explicitly authorized to receive it. If endpoint information can be modified or supplied through an untrusted source without proper validation, a Tool may communicate with an unauthorized endpoint. This can create a risk of credential exposure. Tool metadata can also contain endpoint information that affects Tool execution, while Manuals and user-supplied inputs can influence which Tools are registered. Therefore, security checks are required at different stages of the UTCP Tool execution process.

Existing research has studied several related security areas, including access control, capability-based security, confused-deputy attacks, information-flow protection, runtime policy enforcement, malicious Tool metadata, and AI-agent security. These studies provide useful security concepts for controlling authority and protecting Tool-based systems. However, focused experimental analysis of credential–endpoint binding in UTCP is still limited. In particular, there is a need to examine whether a credential remains restricted to its authorized endpoint when endpoint or trust information is influenced through different Tool and Manual workflows.

In this work, a security analysis of UTCP is presented using a controlled experimental environment. Four security scenarios are evaluated: modified Tool endpoint, malicious Tool metadata, attacker-controlled Manual registration, and untrusted user-supplied Manual registration. The experiments are designed to identify whether these conditions can result in unauthorized endpoint use, credential transmission, or untrusted Manual registration. Based on the observed results, a unified mitigation mechanism is developed to validate credential–endpoint authorization, Tool metadata endpoints, Manual identity and source, and user trust before allowing the corresponding operation.

The main contributions of this work are:

- Analysis of the credential–endpoint binding security property in UTCP.
- Evaluation of four controlled attack scenarios involving Tool endpoints, Tool metadata, Manuals, and user-supplied inputs.
- Development of a unified mitigation mechanism for credential–endpoint authorization and trust validation.
- Experimental evaluation of the mitigation mechanism to detect and block the identified unauthorized conditions.

II. LITERATURE SURVEY

A. Overview of Existing Research

Existing research on AI-agent and tool-calling security has mainly focused on controlling how agents access tools, protecting sensitive information, and preventing unauthorized actions. Access-control and capability-based security approaches provide mechanisms for controlling the authority given to software components. Rajani et al. studied access control, capabilities, and confused-deputy attacks, showing the importance of controlling how authority is obtained and used [1]. Object-capability approaches have also been studied as a way of associating authority with specific software objects and operations [2].

More recent research has focused on the security of AI agents that can interact with external tools. Information-flow approaches have been investigated to control how information moves between tools and other components [3]. Runtime policy enforcement has also been proposed to monitor tool calls and apply security policies during agent execution [4].

These approaches show that security controls are needed not only during tool execution but also when tools and their associated information are selected and registered.

Another area of recent research focuses on malicious tool information and metadata. Security studies of LLM agents have identified risks related to credential exposure, confused-deputy behaviour, malicious tools, and unsafe tool execution [5]–[7]. Approaches based on signed capability information and trusted tool metadata have been proposed to reduce the possibility of attackers influencing tool selection or execution through manipulated information [8]. Protocol-level research, particularly on the Model Context Protocol (MCP), has also identified security concerns involving unauthorized access, credential exposure, token handling, and tool execution [9].

Although these studies provide useful security mechanisms, they address different security properties and environments. Most of them focus on general AI-agent security, information flow, tool selection, or MCP rather than directly examining whether a credential remains restricted to its authorized endpoint in UTCP. This creates a research opportunity to study credential–endpoint binding through controlled UTCP experiments.

B. Review of Key Papers

Rajani et al. studied access control, capabilities, and confused-deputy attacks in software systems [1]. Their work explains how improper authority handling can allow a component to perform actions on behalf of another component. The study is relevant to this research because a UTCP client may act with the authority provided by a configured credential. However, the work is general and does not specifically examine credential–endpoint binding in UTCP.

Koepe studied object-capability security as a method for controlling permission and authority in software systems [2]. The approach focuses on associating authority with specific objects and controlling how that authority is passed between components. This provides a useful foundation for understanding trust and authority in Tool-based systems, but it does not directly address dynamic Tool endpoints or UTCP Manual registration.

Doshi et al. investigated safer Tool use for LLM agents using safety analysis and information-flow control [3]. Their work focuses on identifying unsafe interactions and controlling information flow during tool use. The approach is relevant because credentials and other sensitive information can move between an agent and external Tools. However, the study does not specifically evaluate whether a credential is transmitted only to its authorized UTCP endpoint.

Wang et al. proposed runtime policy enforcement for MCP-based LLM agents [4]. Their approach applies security policies during Tool execution to restrict unsafe operations and information flows. This demonstrates the value of runtime security checks in tool-calling systems. However, the work focuses on MCP and does not specifically evaluate credential–endpoint binding in UTCP.

Ferrag et al. examined security threats affecting LLM-based agents, including credential-related risks, unauthorized actions, and confused-deputy behavior [5]. The study provides a broad view of the attack surface created when AI agents interact with external tools and services. However, it is a general security analysis and does not provide a focused experimental evaluation of UTCP endpoint authorization.

Hossain et al. studied vulnerabilities in agentic large language models across different stages of agent operation [6]. Their work highlights that vulnerabilities can occur when agents interact with external environments and perform actions through tools. The study is useful for understanding the wider security problems of agentic systems, but it does not specifically investigate credential transmission between trusted and unauthorized UTCP endpoints.

Xu et al. presented a comprehensive survey of security issues in LLM agents and discussed how tool use increases the attack surface of agentic systems [7]. The study covers different security threats and protection approaches related to AI agents. However, as a survey, it does not experimentally evaluate credential–endpoint binding within a specific UTCP workflow.

Ali et al. proposed a signed capability approach for securing runtime Tool selection against adversarial metadata manipulation [8]. Their approach aims to ensure that Tool information used during execution can be verified and trusted. This is closely related to the present study because malicious Tool metadata can influence the endpoint used during Tool execution. However, the focus is on Tool-selection integrity rather than directly validating whether a configured credential is authorized for the selected endpoint.

Hou et al. analyzed the security landscape of the Model Context Protocol and identified concerns including unauthorized access, credential exposure, token handling, and confused-deputy behavior [9]. Their work demonstrates that protocol-level Tool execution can introduce security risks when authorization and credential handling are not properly controlled. However, the study focuses on MCP rather than UTCP and does not specifically evaluate the four credential and Manual registration attack paths examined in this research.

TABLE I. COMPARATIVE ANALYSIS OF EXISTING RESEARCH WORKS

Study	Year	Method / Focus	Main Contribution
Rajani et al. [1]	2016	Access Control and Capabilities	Analyzed authority control and confused-deputy attacks
Koepe [2]	2019	Object-Capability Security	Studied permission and authority management
Doshi et al. [3]	2026	Information-Flow and Tool Safety	Investigated safer tool use for LLM agents
Wang et al. [4]	2026	Runtime Policy Enforcement	Applied runtime security policies to MCP-based agents
Ferrag et al. [5]	2026	LLM-Agent Threat Analysis	Reviewed attacks and defenses affecting LLM agents
Hossain et al. [6]	2026	Agentic LLM Vulnerability Analysis	Studied vulnerabilities in agentic AI systems
Xu et al. [7]	2026	LLM-Agent Security Survey	Reviewed security issues in LLM-based agents
Ali et al. [8]	2026	Signed Capability Verification	Addressed malicious Tool metadata and Tool selection

III. PROPOSED FRAMEWORK AND METHODOLOGY

A. System Overview

The proposed framework is designed to protect sensitive credentials during Tool execution in the Universal Tool Calling Protocol (UTCP). The main objective is to maintain a strong relationship between a credential and its authorized endpoint. A credential configured for a trusted service should not be automatically used when the Tool endpoint is changed, supplied through untrusted metadata, or introduced through an untrusted Manual.

The framework follows the complete UTCP Tool execution flow, starting from the registration of a Manual and ending with the execution of the requested Tool. At each important stage, security checks are applied before the operation is allowed to continue.

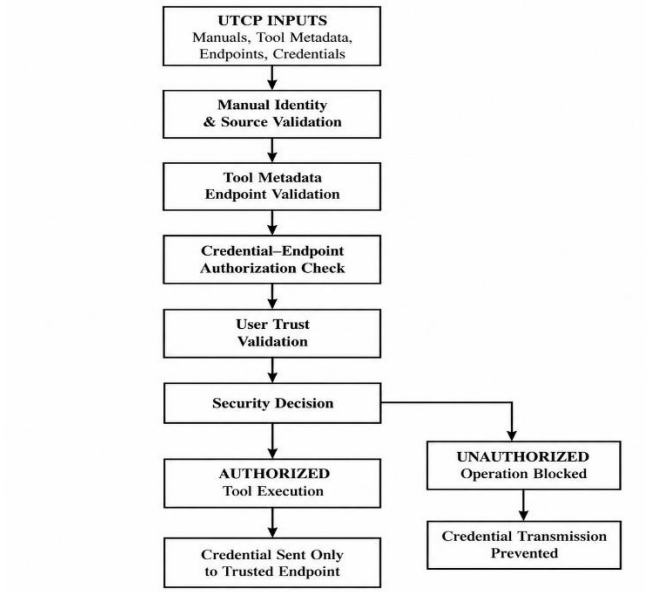


Fig.1 Proposed Credential–Endpoint Binding Security Framework

B. System Architecture

The experimental system was developed to analyze credential–endpoint binding in the Universal Tool Calling Protocol (UTCP). The architecture consists of a UTCP client, a trusted Manual, Tool metadata, a configured credential, and two local HTTP servers representing trusted and unauthorized endpoints.

The trusted endpoint, Server A (127.0.0.1:8001), represents the legitimate service for which the credential is intended. The unauthorized endpoint, Server B (127.0.0.1:8002), represents a destination that should not receive the credential. The credential SECRET_A is configured for the trusted endpoint.

Under normal operation, the UTCP client registers Manual A **(**manual_a**)**, discovers the Tool get_secret_data, and executes the Tool through the trusted endpoint. The request containing the credential is therefore directed to Server A.

The architecture was then used to evaluate whether endpoint information or Manual registration could be manipulated during different stages of the UTCP workflow. The experiments examined changes to the stored Tool endpoint, endpoint information provided through Tool metadata, attacker-controlled Manual registration, and Manuals supplied through an untrusted user-input path.

The mitigation mechanism is placed between these operations and the Tool execution process.It validates the Manual identity and source, checks Tool metadata endpoints, verifies the credential–endpoint relationship, and validates user trust. If the validation succeeds, the Tool execution is allowed. If an unauthorized condition is detected, the operation is blocked and the credential is prevented from being transmitted to the unauthorized endpoint.

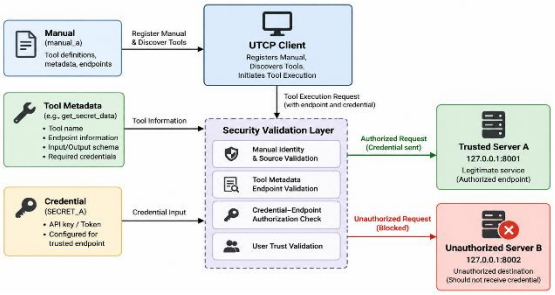


Fig. 2 System architecture for the UTCP credential–endpoint binding security experiments.

C. Security Test Scenarios

To evaluate the security of the UTCP implementation, four controlled test scenarios were developed. Each scenario focuses on a different point where endpoint or trust information can influence Tool execution or Manual registration.

Modified Tool Endpoint: In the first test, the endpoint of the trusted Tool was changed from Server A **(**127.0.0.1:8001**)** to Server B **(**127.0.0.1:8002**)**. The Tool was then executed using the configured credential SECRET_A. The unauthorized server received the credential, demonstrating that the credential could be transmitted when the stored Tool endpoint was modified without an authorization check.

Malicious Tool Metadata: In the second test, the Tool metadata provided an endpoint pointing to the unauthorized Server B instead of the trusted Server A. UTCP accepted the endpoint from the Tool metadata and used it during Tool execution. As a result, SECRET_A was transmitted to the unauthorized endpoint. This demonstrates the need to validate endpoint information obtained from Tool metadata before execution.

Attacker-Controlled Manual Registration: In the third test, an attacker-controlled Manual containing a Tool associated with the unauthorized endpoint was supplied for registration. UTCP successfully accepted and registered the Manual and its Tool. This demonstrates that Manual identity and source need to be validated before registration.

Untrusted User-Supplied Manual Registration: In the fourth test, a Manual was supplied through an untrusted user-input path and passed to the UTCP registration process. The Manual was successfully registered in the attack scenario. This demonstrates the need to verify whether the Manual supplied by a user is trusted before allowing registration.

These four scenarios were then used to evaluate the proposed mitigation mechanism. The first two tests focused on unauthorized credential transmission, while the third and fourth tests focused on unauthorized Manual registration.

A unified mitigation mechanism was developed to address the security conditions identified in the four experiments. The main purpose of the mitigation is to ensure that a credential is used only with its authorized endpoint and that untrusted Manuals are not accepted without validation.

The mitigation performs the following checks:

Credential–Endpoint Validation: The credential is associated with its trusted endpoint. Before a credential-bearing Tool call is executed, the requested endpoint is checked against the authorized endpoint.

Tool Metadata Validation: The endpoint provided through Tool metadata is compared with the trusted endpoint. If an unauthorized endpoint is detected, Tool execution is blocked.

Manual Identity and Source Validation: The Manual name and source are checked against the trusted Manual configuration. An attacker-controlled Manual is rejected before it can be registered.

User Trust Validation: Manuals supplied through an untrusted user-input path are checked before registration. If the Manual is not associated with a trusted identity, registration is blocked.

Operation Blocking: When any validation fails, the corresponding operation is stopped. For credential-related cases, the credential is not transmitted to the unauthorized endpoint.

The mitigation was implemented as a unified security layer around the UTCP client and evaluated against all four attack scenarios. The results showed that the identified unauthorized conditions could be detected and blocked by applying these validation checks before Tool execution or Manual registration.

IV. EXPERIMENTAL SETUP / IMPLEMENTATION

The experimental setup was developed to identify and evaluate credential–endpoint binding vulnerabilities in the Universal Tool Calling Protocol (UTCP). The implementation uses a UTCP client, a trusted Manual, a Tool, a configured credential, and two local HTTP servers. The experiments were first performed without mitigation to observe the vulnerable behavior. The mitigation was then applied to the same test cases to verify whether the identified conditions could be detected and blocked.

A. Experimental Environment:

The experiments were conducted using Python 3.14.6, UTCP 1.1.3, and utcp-http 1.1.11. Two local HTTP servers were used to represent different trust levels.

- Trusted Server A: 127.0.0.1:8001
- Unauthorized Server B: 127.0.0.1:8002
- Trusted Manual: manual_a
- Tool: get_secret_data
- Credential: SECRET_A

Server A represents the legitimate endpoint for which the credential is intended. Server B represents an endpoint that should not receive the credential.

B. Tool and Credential Configuration

A trusted Manual named manual_a was registered with the UTCP client. The Manual provided the Tool get_secret_data, which was used throughout the experiments.

Under normal operation, the Tool communicates with Server A. The credential SECRET_A is configured for this trusted endpoint. The main security property evaluated in this work is that a credential should only be transmitted to the endpoint explicitly authorized for that credential.

This configuration provides a controlled environment in which endpoint changes and different Manual registration conditions can be observed.

C. Security Test Implementation

Four controlled security tests were implemented to examine different ways in which the UTCP workflow could be influenced.

Test 1 – Modified Tool Endpoint:

The stored endpoint of the trusted Tool was changed from Server A to Server B. The Tool was then executed to determine whether the configured credential would follow the modified endpoint. The experiment showed that the unauthorized server could receive SECRET_A.

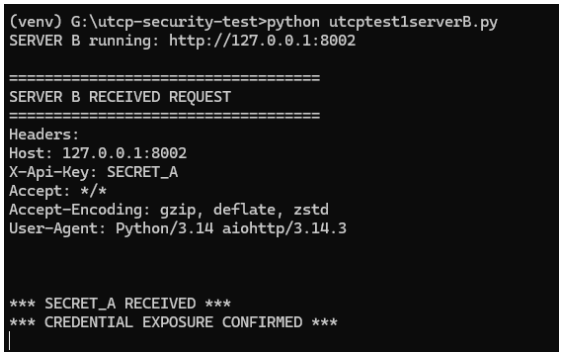


Fig. 3 Credential transmitted to the unauthorized endpoint.

Test 2 – Malicious Tool Metadata:

Tool metadata containing Server B as the endpoint was provided during the Tool discovery process. UTCP accepted the endpoint specified in the metadata and used it for Tool execution. The unauthorized server received SECRET_A.

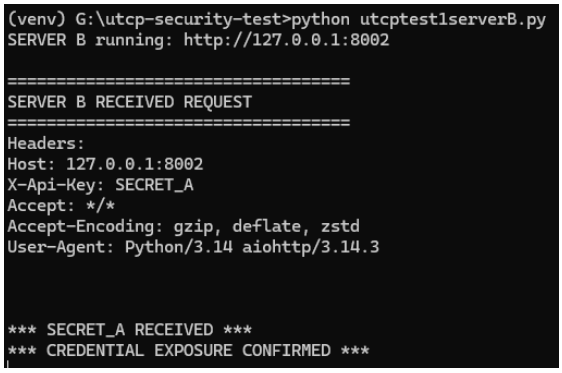


Fig. 4 Credential transmitted through malicious Tool metadata.

Test 3 – Attacker-Controlled Manual Registration:

An attacker-controlled Manual containing a Tool associated with the unauthorized endpoint was supplied for registration. UTCP accepted the Manual and registered the Tool, demonstrating the need for Manual identity and source validation.

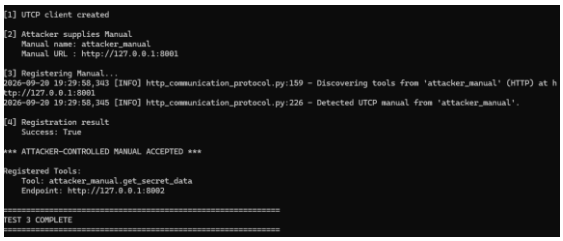


Fig. 5 Attacker-controlled Manual accepted by UTCP

Test 4 – Untrusted User-Supplied Manual Registration:

A Manual supplied through an untrusted user-input path was passed to the UTCP registration process. The Manual was successfully registered in the attack scenario, demonstrating the need for explicit user-trust validation.

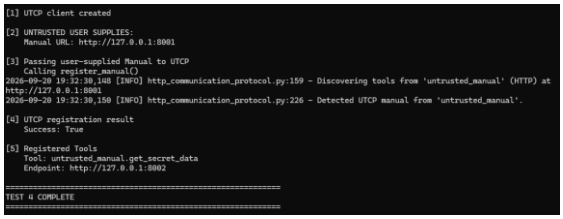


Fig. 6 Untrusted user-supplied Manual accepted by UTCP

Tests 1 and 2 therefore focused on unauthorized credential transmission, while Tests 3 and 4 focused on unauthorized Manual registration.

D. Mitigation Implementation

After identifying the vulnerable behavior, a unified mitigation mechanism was developed around the UTCP client. The mitigation contains separate validation checks for the different attack paths while following the same security principle.

First, the mitigation establishes the trusted relationship between the credential and endpoint. In this experiment, SECRET_A is associated with http://127.0.0.1:8001. Before a credential-bearing Tool call is allowed, the requested endpoint is compared with the endpoint authorized for the credential. If the endpoints do not match, the Tool call is blocked and the credential is not transmitted.

Second, the mitigation validates endpoints obtained from Tool metadata. The endpoint specified by the Tool metadata is compared with the trusted endpoint. If the metadata specifies Server B instead of Server A, the metadata is treated as unauthorized and Tool execution is blocked.

Third, the mitigation validates the identity and source of a Manual before allowing it to be registered. The Manual name and its source are compared against the trusted Manual configuration. A Manual that does not belong to the trusted configuration is rejected.

Finally, the mitigation checks Manuals supplied through an untrusted user-input path. Even if the supplied Manual contains a valid-looking Tool, it is not registered unless the Manual satisfies the required trust validation.

The mitigation was therefore mapped to the four tests as follows:

Test 1: Credential–endpoint authorization

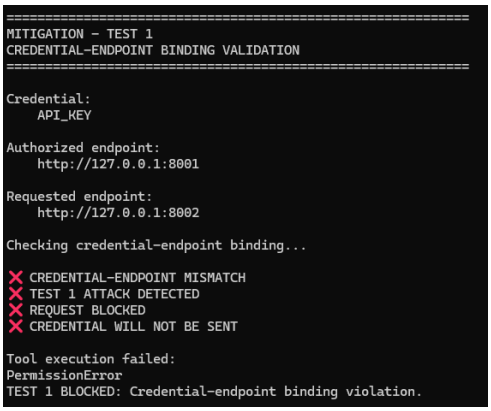


Fig. 7 Unauthorized credential transmission blocked.

Test 2: Tool metadata endpoint validation

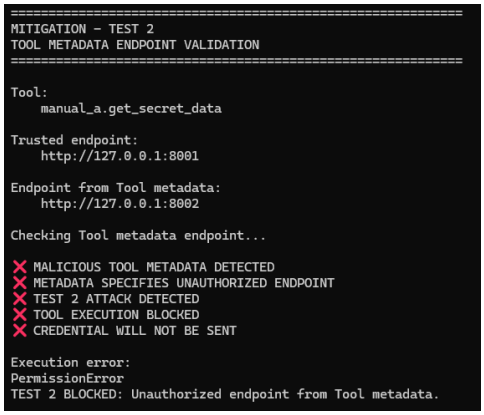


Fig. 8 Malicious Tool metadata blocked.

Test 3: Manual identity and source validation

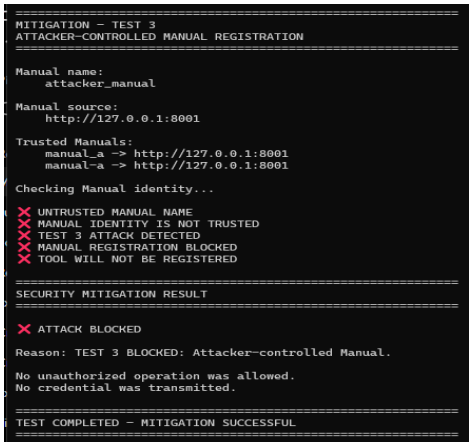


Fig. 9 Attacker-controlled Manual registration blocked

Test 4: Untrusted user Manual validation

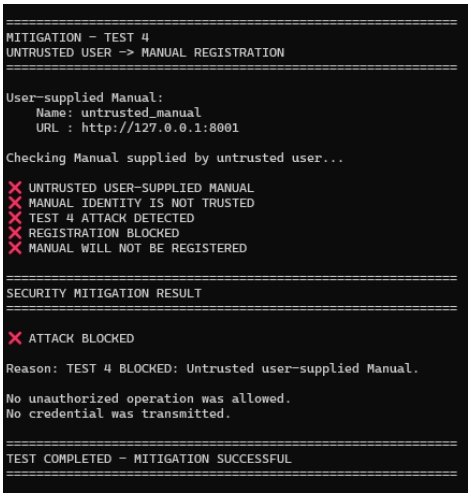


Fig. 10 Untrusted Manual registration blocked

When any validation check fails, the corresponding operation is stopped. For Tests 1 and 2, this prevents the credential from being transmitted to Server B. For Tests 3 and 4, the untrusted Manual is prevented from being registered.

E. Experimental Evaluation

The experimental evaluation was performed using the same controlled UTCP environment for both the vulnerable and mitigated configurations. The environment consisted of Python 3.14.6, UTCP 1.1.3, and utcp-http 1.1.11, with Server A (127.0.0.1:8001) representing the trusted endpoint and Server B (127.0.0.1:8002) representing the unauthorized endpoint. The credential SECRET_A was configured for the trusted endpoint.

Four security scenarios were executed. In the first scenario, the stored Tool endpoint was modified from Server A to Server B, resulting in the credential being transmitted to the unauthorized server. In the second scenario, the Tool metadata specified Server B as the endpoint, which also resulted in credential transmission to the unauthorized endpoint. The third scenario tested an attacker-controlled Manual and showed that the Manual could be registered without the mitigation. The fourth scenario evaluated a Manual supplied through an untrusted user-input path and demonstrated that the Manual could also be registered in the vulnerable configuration.

After the vulnerable behaviour was established, the proposed mitigation mechanism was applied to the same four scenarios. The mitigation validated the credential–endpoint relationship for Test 1, the Tool metadata endpoint for Test 2, and Manual identity and trust for Tests 3 and 4. The unauthorized conditions were detected and the corresponding operations were blocked. For Tests 1 and 2, the credential was prevented from being transmitted to Server B. For Tests 3 and 4, Manual registration was prevented before the untrusted Manual could proceed to Tool registration or execution.

The evaluation therefore demonstrates that the proposed security layer can detect the tested unauthorized conditions and enforce the intended security property: a credential should only be transmitted to the endpoint explicitly authorized for that credential.

V. RESULTS AND DISCUSSION

A. Experimental Results

The results obtained from the four controlled security tests are summarized based on the behaviour observed before and after applying the proposed mitigation mechanism. The vulnerable configuration was used to identify whether unauthorized endpoint use or Manual registration could occur, while the mitigated configuration was used to determine whether the same conditions were detected and blocked.

Modified Tool Endpoint: The Tool endpoint was changed from the trusted Server A (127.0.0.1:8001) to Server B (127.0.0.1:8002). In the vulnerable configuration, Server B received the credential SECRET_A. After mitigation, the credential–endpoint binding check detected the mismatch between the authorized and requested endpoints, and the Tool request was blocked before credential transmission.

Malicious Tool Metadata: The Tool metadata specified Server B as the endpoint instead of the trusted Server A. In the vulnerable configuration, UTCP used the endpoint provided by the metadata and SECRET_A was transmitted to Server B. After mitigation, the metadata endpoint was compared with the trusted endpoint. The mismatch was detected and Tool execution was blocked.

Attacker-Controlled Manual Registration**:** An attacker-controlled Manual named attacker_manual was supplied for registration. In the vulnerable configuration, the Manual was accepted and its Tool could be registered. After mitigation, the Manual identity was checked against the trusted Manual configuration. Since attacker_manual was not trusted, registration was blocked.

Untrusted User-Supplied Manual Registration: A Manual supplied through an untrusted user-input path was passed to the UTCP registration process. The vulnerable configuration accepted the supplied Manual. After mitigation, the Manual identity and trust conditions were checked before registration, and the untrusted Manual was blocked.

TABLE II. EXPERIMENTAL RESULTS

Test	**Attack Scenario**	**Vulnerable Result**	**Mitigated Result**
Test 1	Modified Tool Endpoint	SECRET_A received by Server B	Credential transmission blocked
Test 2	Malicious Tool Metadata	SECRET_A received by Server B	Tool execution blocked
Test 3	Attacker-Controlled Manual	Manual accepted	Manual registration blocked
Test 4	Untrusted User-Supplied Manual	Manual accepted	Manual registration blocked

The results demonstrate that the proposed mitigation addressed the unauthorized conditions observed in all four controlled experiments. Tests 1 and 2 primarily demonstrated protection of the credential–endpoint relationship, while Tests 3 and 4 demonstrated protection of the Manual registration process.

B. Comparative Analysis

A comparison was performed between the vulnerable UTCP configuration and the configuration protected by the proposed mitigation mechanism. The comparison focuses on whether the unauthorized condition was successfully performed and whether the mitigation prevented the corresponding operation.

For Test 1, the vulnerable configuration allowed the modified Tool endpoint to direct SECRET_A to Server B. The mitigation detected the mismatch between the credential's authorized endpoint and the requested endpoint and blocked the request.

For Test 2, the vulnerable configuration accepted the unauthorized endpoint provided through Tool metadata, resulting in credential transmission to Server B. The mitigation validated the metadata endpoint against the trusted endpoint and prevented Tool execution when the endpoints differed.

For Tests 3 and 4, the vulnerable configuration accepted the tested untrusted Manual registration paths. The mitigation introduced trust checks before registration and blocked the attacker-controlled and untrusted user-supplied Manuals.

Thus, the comparison shows a clear difference between the tested vulnerable and mitigated configurations: the vulnerable configuration allowed the tested unauthorized conditions, whereas the mitigation prevented those conditions at the relevant security-checking stage.

C. Discussion

The experimental results indicate that endpoint and trust information can influence the security of UTCP Tool execution and Manual registration when appropriate validation is not applied. The first two tests demonstrate the importance of maintaining a binding between a configured credential and its authorized endpoint. In both cases, an unauthorized endpoint was able to become the destination of a credential-bearing Tool request in the vulnerable configuration.

The results from Tests 3 and 4 further show that trust validation is also required during Manual registration. A Manual should not be considered trusted only because its source is reachable or because it can be successfully registered. The identity and trust relationship of the Manual must also be checked before it is allowed to participate in the Tool execution workflow.

The proposed mitigation applies these checks at different stages of the UTCP workflow. Credential–endpoint validation is applied before credential-bearing execution, metadata validation is applied before accepting an endpoint supplied through Tool information, and Manual trust validation is applied before registration. This separation allows the mitigation to address the different conditions identified in the four experiments.

Overall, the results support the security property examined in this study: a credential should only be transmitted to the endpoint explicitly authorized for that credential. The experiments were conducted in a controlled local environment, so the findings represent the tested UTCP configuration and should not be generalized to every possible UTCP deployment.

VI. CONCLUSION

This study presented a security analysis of credential–endpoint binding in the Universal Tool Calling Protocol (UTCP). A controlled experimental environment was developed using a UTCP client, a trusted endpoint, an unauthorized endpoint, a configured credential, and four security test scenarios.

The experiments demonstrated that modification of a Tool endpoint and manipulation of Tool metadata could result in credential transmission to an unauthorized endpoint in the tested vulnerable configuration. The Manual registration experiments further demonstrated that attacker-controlled and untrusted user-supplied Manuals could be accepted without the proposed trust validation.

To address these conditions, a unified mitigation mechanism was developed. The mechanism validates credential–endpoint authorization, Tool metadata endpoints, Manual identity and source, and user trust before allowing the corresponding operation. The mitigation successfully detected and blocked the unauthorized conditions identified in all four experiments.

The study demonstrates the importance of maintaining explicit trust relationships between credentials, endpoints, Tool metadata, and Manuals in UTCP-based Tool execution. Future work can extend the evaluation to additional authentication mechanisms, deployment environments, endpoint configurations, and security scenarios, as well as evaluate the performance overhead and broader applicability of the mitigation mechanism.

VII. FUTURE WORK

The present study was evaluated using a controlled local environment with Python 3.14.6, UTCP 1.1.3, utcp-http 1.1.11, and two local endpoints. Future work can extend the evaluation to different UTCP deployment environments, authentication mechanisms, and endpoint configurations.

Additional security scenarios can also be investigated, including other forms of Tool metadata manipulation, Manual modification, credential substitution, endpoint redirection, and trust-boundary violations. The mitigation mechanism can be further integrated into the UTCP implementation rather than operating as an external security layer.

Future studies can also evaluate the performance overhead, detection effectiveness, and false-positive rate of the proposed security checks. Testing with larger Tool collections and more complex agent workflows would help determine how the mitigation performs in practical UTCP-based applications.

Finally, future research can investigate automated trust management and stronger cryptographic mechanisms for establishing and maintaining the relationship between credentials, Tools, Manuals, and authorized endpoints.

VII. REFERENCES

[1] V. Rajani, D. Garg, and T. Rezk, “On Access Control, Capabilities, Their Equivalence, and Confused Deputy Attacks,” in *Proc. 2016 IEEE 29th Computer Security Foundations Symposium (CSF)*, 2016, pp. 150–163, doi: 10.1109/CSF.2016.18.

[2] A. Doshi, Y. Hong, C. Xu, E. Kang, A. Kapravelos, and C. Kästner, “Towards Verifiably Safe Tool Use for LLM Agents,” in *Proc. IEEE/ACM 48th International Conference on Software Engineering: New Ideas and Emerging Results (ICSE-NIER)*, 2026, pp. 201–205, doi: 10.1145/3786582.3786839.

[3] S. Wang, S. Zhu, and R. Li, “Runtime Policy Enforcement for MCP-Based LLM Agents,” *Electronics*, vol. 15, no. 13, Art. no. 2829, 2026, doi: 10.3390/electronics15132829.

[4] Y. Tang, Y. Liu, J. Lan, Z. Yan, and E. Gelenbe, “Security of LLM-Based Agents Regarding Attacks, Defenses, and Applications: A Comprehensive Survey,” *Information Fusion*, vol. 127, Art. no. 103941, 2026, doi: 10.1016/j.inffus.2025.103941.

[5] M. J. Hossain, M. A. Hossain, and N. Ansari, “On Understanding, Identifying, and Mitigating Vulnerabilities in Agentic Large Language Models,” arXiv preprint arXiv:2608.10530, 2026.

[6] B. Ali, M. R. Anwar, and T. Minhas, “Signed but Unsafe: Securing Runtime Tool Selection in LLM Agents under Adversarial Metadata Injection,” SSRN, 2026, doi: 10.2139/ssrn.7199341.

[7] X. Hou, Y. Zhao, S. Wang, and H. Wang, “Model Context Protocol (MCP): Landscape, Security Threats, and Future Research Directions,” *ACM Transactions on Software Engineering and Methodology*, vol. 35, no. 10, Art. no. 302, 2026, doi: 10.1145/3796519.

[8] R.-I. Radulescu, “Universal Tool Calling Protocol (UTCP) 1.0.0,” UTCP RFC, 2026.

[9] Universal Tool Calling Protocol, “Security Considerations,” UTCP Documentation, 2025.

[10] Universal Tool Calling Protocol, “HTTP Protocol,” UTCP Documentation, 2025.

[11] Universal Tool Calling Protocol, “Universal Tool Calling Protocol Specification,” GitHub Repository, 2026.

[12] Universal Tool Calling Protocol, “Python UTCP,” GitHub Repository, 2026.